

AI-ASSISTED CYBERSECURITY RISK ASSESSMENT & SECURITY AUDIT PLATFORM

To fulfil mini project for Security Risk and Management Audit

Lecturer: ROSALINA, B.Sc., M.Sc



Compile by:

Halima Abdirizak Mohamed (001202400224)

Diah Safitri Pane (001202400208)

Tentin Nofa Tuzika (001202400134)

PRESIDENT UNIVERSITY

FACULTY OF COMPUTER SCIENCE

NORH CIKARANG

FEBRUARY 2026

EXECUTIVE SUMMARY

This document describes the design and implementation of an AI-Based Security Audit and Risk Assessment Platform, designed as a mini-GRC (Governance, Risk, Compliance) solution for web information systems. The proposed solution employs the NIST Cybersecurity Framework (CSF) as the primary audit standard. The CSF is organized in five primary functions: Identify, Protect, Detect, Respond, and Recover. Vulnerability identification is performed using the OWASP Top 10 standard vulnerability taxonomy, covering 19 common web information systems vulnerability types. Risk scoring is computed using the standard formula: $\text{Risk} = \text{Likelihood} * \text{Impact}$. An AI Vulnerability Explainer powered by Ollama AI is incorporated in the proposed solution to communicate the results in non-technical terms that can be easily understood by management. The proposed solution supports the entire process of security audit, including asset registration, threat identification, control audits, evidence collection, compliance scoring, and report generation. It can be used as a junior cybersecurity auditor's assistant for organizations that seek assurance that their security controls are not only documented but implemented and operating effectively.

INTRODUCTION

1. BACKGROUND

Risk Assessment and Security Audits are both fundamental to an Information Security Management System (ISMS). They provide the foundation to identify and assess potential risks to the organization's information assets and to ensure that appropriate controls are in place to address those risks. In a Risk Assessment, there is a focus on identifying and assessing the risks; in a Security Audit, the focus is to verify that the controls that were identified as necessary to manage the risks are implemented and functioning correctly.

Many organizations experience a significant difference between what they claim their security posture to be versus what their true security posture is. For example, many organizations have security policies and procedures documented, however they do not have the technology to enforce them. Additionally, many organizations may have controls in place, but the controls may be non-operational due to one or more of the following: environmental changes, misconfiguration, or simply user error. The difference between an organization's claimed vs. actual security posture can increase an organization's exposure to attacks from increasingly sophisticated and evolving cyber threats.

Governance, Risk, and Compliance (GRC) solutions are being increasingly used by modern organizations to raise their efficiency and meet the mounting challenges in their environment. GRC solutions enable organizations to automate the whole cycle of risk analysis, control verification, and compliance reporting. Thus, these solutions enable organizations to continuously and systematically view their security status. Instead of relying on traditional methods such as risk analysis and compliance reporting by external consultants, GRC solutions are enabling organizations to raise the competencies of their internal security professionals to carry out these evaluations.

This project focuses on the conceptualization and creation of a mini GRC platform for web application security audit purposes. This platform has various features such as a risk assessment tool that complies with the OWASP Top 10 taxonomy for vulnerability identification. Besides that, it integrates a structured audit process based on the NIST Cybersecurity Framework (CSF) for risk assessment. What's more, the platform is equipped with an AI assistant powered by Ollama AI to help demystify advanced security vulnerabilities in layman's terms for management understanding. It's essentially a helpful sidekick designed to assist junior cybersecurity auditors step by step throughout the process.

2. OBJECTIVES

- a. Design and implement a GRC platform for risk assessment and web application audits.

- b. Integrate the NIST Cybersecurity Framework (CSF) as the main audit process.
- c. Fully implement the OWASP Top 10 vulnerability taxonomy for structured identification.
- d. Implement an Ollama AI-based Vulnerability Explainer.
- e. Implement automation for compliance score calculation, findings generation, and report generation.

3. SCOPE

The scope of this project is limited only to web- based information systems. One should be aware that this platform does not perform vulnerability scans or penetration testing. On the contrary, it is geared to replicate an auditor's actions. Also, it should be noted that this framework's scope is in line with the five most important NIST CSF functions. Moreover, it should also be noted that the AI of this platform is only capable of explaining vulnerabilities.

4. FRAMEWORK SELECTION

4.1. Framework Overview

The NIST Cybersecurity Framework (CSF) is a risk management approach for addressing cybersecurity risks that the National Institute of Standards & Technology developed. NIST CSF has in it as the foundation of any complete cybersecurity program five key functions. These functions are an inseparable continuum that when combined represent the total security posture.

4.2. Core Functions of CSF

FUNCTION	DESCRIPTION	AUDIT FOCUS
IDENTIFY (ID)	Understand the organizational context, assets, and risk environment	Asset inventory, risk assessment, governance

FUNCTION	DESCRIPTION	AUDIT FOCUS
PROTECT (PR)	Implement safeguards to ensure delivery of critical services	Access control, data security, training, maintenance
DETECT (DE)	Develop activities to identify cybersecurity events	Monitoring, detection processes, anomaly detection
RESPOND (RS)	Take action regarding detected cybersecurity incidents	Response planning, communications, analysis
RECOVER (RC)	Restore impaired capabilities or services	Recovery planning, improvements, communications

4.3. Justification for Framework Selection

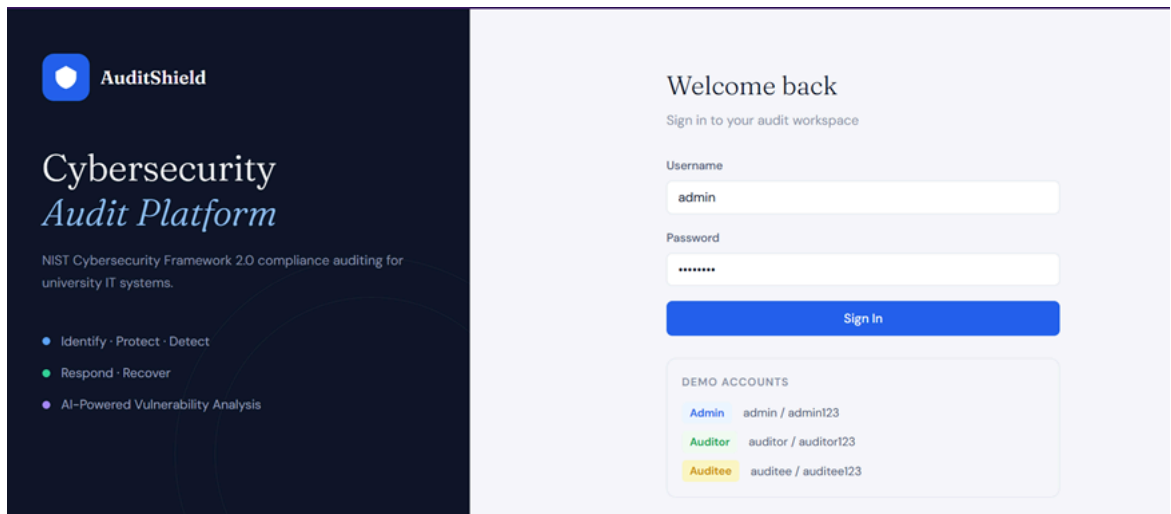
NIST CSF was selected as the framework for this project due to its comprehensiveness. Firstly, its coverage of the entire security lifecycle from asset identification to any event response, remediation, detection, etc. Secondly, its function-based approach provides a great fit for the implementation of the audit checklist format as it naturally aligns with the audit checklist format itself. Besides, NIST CSF is a popular standard that has been broadly adopted by different industries, which would facilitate real world interpretation of the platform's output.

5. MAIN SYSTEM CAPABILITIES

The system is meant to function as an assistant for junior cybersecurity auditors and will walk users through the entire process of conducting a cybersecurity audit for a web-based information system. The following table shows a summary of the system's capabilities:

ACTIVITY	DESCRIPTION	RELATED MODULE
Risk Assessment	Analyze web assets, identify OWASP-based threats, and calculate risk scores using $\text{Likelihood} \times \text{Impact}$	Modules 3, 4, 5

ACTIVITY	DESCRIPTION	RELATED MODULE
Security Audit	Check whether NIST CSF controls exist and are implemented across all five functions	Module 6
Evidence Collection	Allow auditors to upload screenshots, PDFs, and configuration files as audit evidence	Module 7
Compliance Check	Automatically calculate compliance percentage based on audit results	Module 8
AI Consultation	Explain vulnerabilities and findings in non-technical language using Ollama AI	Module 10
Audit Report and Risk Assessment Report	Generate structured PDF Audit Report including executive summary, findings, and compliance results also exportable Risk Assessment Report with risk matrix, asset exposure, and treatment plan	Module 11
User Manual	Guides user and gives them a detailed step by step on how to use the website	Module 12



SYSTEM MODULES

1. USER & AUDITOR MANAGEMENT

The system provides a role-based access control (RBAC) feature that allows three different roles for users: Admin, Auditor, and Auditee. Every role has different access permissions according to their tasks in the audit process.

ROLE	PERMISSIONS
ADMIN	Manage users, assign auditors to organizations, view all reports
AUDITOR	Conduct risk assessments, fill audit checklists, upload evidence, generate reports
AUDITEE	View assigned audit results, respond to findings, upload evidence upon request

 **AuditShield**

Cybersecurity
Audit Platform

NIST Cybersecurity Framework 2.0 compliance auditing for university IT systems.

- Identify · Protect · Detect
- Respond · Recover
- AI-Powered Vulnerability Analysis

Welcome back

Sign in to your audit workspace

Username

admin

Password

Sign In

DEMO ACCOUNTS

Admin

admin / admin123

Auditor

auditor / auditor123

Auditee

auditee / auditee123

All Users

NAME	USERNAME	EMAIL	ROLE	CREATED	ACTIONS
System Administrator	admin	admin@university.edu	Admin	2026-02-26	You
Lead Auditor	auditor	auditor@university.edu	Auditor	2026-02-26	
IT Department	auditee	it@university.edu	Auditee	2026-02-26	

2. ORGANIZATION PROFILE

Prior to the audit process, the Auditee or Admin enters an organization profile. This data is used by the system to determine the exposure level of the organization, which in turn determines the assumptions of probability used in the process.

INPUT FIELD	EXAMPLE VALUE
Organization Name	President University
Business Sector	Higher Education
Number of Employees	100 - 1000
System Type	Website

Organization Profile

NIST CSF 2.0

Organization Details

Organization Name

Presidentas Universitas

Industry Sector

Education

Organization Size

Medium (100–1000 staff)

Contact Email

president@ac.id

Description

This audit evaluates the cybersecurity risks and security controls protecting Presidentas Universitas core information systems. The assessment focuses on the student information system, learning management system, internal network, user access management, database servers, and backup processes. The objective is to assess risk levels and determine the effectiveness of implemented security controls.

Save Organization Profile

Presidentas Universitas is a private higher education institution offering undergraduate and postgraduate programs. The university serves approximately 6,500 students and employs 400 academic and administrative staff. It operates a cloud-based student portal, a learning management system, and a database of student records.

Save Organization Profile

Exposure Assessment

EXPOSURE LEVEL

High

Industry: Education

Size: Medium

Scope: University IT Systems — Full NIST CSF Audit

Framework: NIST Cybersecurity Framework 2.0

Exposure Logic: Education sector with large staff size results in **High exposure**. This guides the depth of controls assessment required.

3. ASSET INVENTORY

Users can register all relevant information assets related to the audited website. The system uses the CIA value provided by the registrant to calculate the asset's criticality score.

FIELD	DESCRIPTION	EXAMPLE
Asset Name	Identifier for the asset	Student Portal (LMS)

Owner	Responsible department/person	IT Department
Location	Physical or logical location	Cloud Server (AWS)
Type	Category of asset	Web Application
CIA Values	Confidentiality / Integrity / Availability ratings (1–5)	High / High / Medium

Asset Inventory
NIST CSF 2.0

Register New Asset

Asset Name
Student Database

Asset Type
Database

Asset Owner
IT Department

Location
Data Centre

Description
It contains personal details, academic records, course registrations, grades, financial records, and contact information. The system is accessed by ad

Confidentiality (C) 1–5
4

Integrity (I) 1–5
5

Availability (A) 1–5
4

Criticality Score
4.33

= $\text{avg}(C, I, A) \times \text{max}(C, I, A) / 5$

4.

THREAT & VULNERABILITY IDENTIFICATION (OWASP-Based)

A. Purpose

This module enables the identification and association of vulnerabilities with registered assets. The process flow is: Asset → OWASP Vulnerabilities → Threats → Impact → Risk Score. The system loads the built-in library with all the vulnerabilities based on the complete OWASP Top 10, covering 19 types of vulnerabilities.

B. Built-In Vulnerability Library (OWASP Top 10)

NO	CATEGORY	VULNERABILITY
1	Injection	SQL Injection

NO	CATEGORY	VULNERABILITY
2	Injection	Command Injection
3	Injection	LDAP Injection
4	Broken Authentication	Weak Password Policy
5	Broken Authentication	No Account Lockout
6	Broken Authentication	Session Hijacking
7	Sensitive Data Exposure	No HTTPS/TLS
8	Sensitive Data Exposure	Weak Encryption
9	Sensitive Data Exposure	Exposed Database Backup
10	Access Control Failures	IDOR (Insecure Direct Object Reference)
11	Access Control Failures	Privilege Escalation
12	Security Misconfiguration	Default Credentials
13	Security Misconfiguration	Directory Listing Enabled
14	Security Misconfiguration	Exposed Admin Panel
15	Security Misconfiguration	Open Unnecessary Ports
16	Cross-Site Attacks	Cross-Site Scripting (XSS)
17	Cross-Site Attacks	Cross-Site Request Forgery (CSRF)
18	Logging & Monitoring Failure	No Audit Logs
19	Dependency & Software Issues	Outdated Server Software

C. Student System Behavior

Upon selection of the asset, the auditor is presented with a checkbox interface displaying all 19 types of vulnerabilities. Once the auditor selects the detected or suspected vulnerability, the system automatically generates a likelihood score,

business impact description, and risk score for the selected vulnerability without the need for user input.

Threat & Vulnerability Identification

NIST CSF

Step 1 — Select Asset

Student Database

Step 2 — Select Vulnerabilities Detected or Suspected

Asset: Student Database — Check all that apply

Select AllClear All

INJECTION

3 vulnerabilities

☒ SQL Injection

INJ-001 L:4 × I:5 = 20

Database theft — attacker can read, modify, or delete all university data including student records and credentials.

Audit checklist: Verify input validation and parameterized queries are enforced on all database-facing fields.

☒ Command Injection

INJ-002 L:3 × I:5 = 15

Full server compromise — attacker executes arbitrary OS commands, potentially taking over the server.

Audit checklist: Verify system commands are never constructed from user-supplied input; use safe API alternatives.

☒ LDAP Injection

INJ-003 L:2 × I:4 = 8

Directory traversal — attacker manipulates LDAP queries to bypass authentication or expose directory data.

Audit checklist: Verify LDAP queries use proper escaping and input sanitization before directory lookups.

D. Automatic Risk Mapping

VULNERABILITY	AUTO-ASSIGNED IMPACT
SQL Injection	Database theft / data exfiltration
XSS	Account hijacking / session theft
CSRF	Unauthorized transaction execution
Weak Password Policy	Account takeover
No Audit Logs	Incident goes undetected
Outdated Server Software	Remote exploitation
Session Hijacking	Impersonation / data breach

No HTTPS/TLS	Man-in-the-middle attack
IDOR	Unauthorized data access
Privilege Escalation	Administrative access by unauthorized user

Threat & Vulnerability Identification

NIST CSF 2.0

SENSITIVE DATA EXPOSURE		3 vulnerabilities
☒ No HTTPS / TLS DATA-001 L:4 × I:4 = 16 <i>Data interception — credentials and personal data transmitted in plaintext can be captured on the network.</i> ⓘ Audit checklist: Verify TLS certificate is installed, HTTPS is enforced site-wide, and HTTP is redirected to HTTPS.	☐ Weak Encryption DATA-002 L:3 × I:4 = 12 <i>Data exposure — use of weak algorithms (MD5, DES) means encrypted data can be cracked to reveal passwords or PII.</i> ⓘ Audit checklist: Verify data at rest uses AES-256 or equivalent; passwords hashed with bcrypt/Argon2; no MD5 or SHA-1 for sensitive data.	☐ Exposed Database Backup DATA-003 L:3 × I:5 = 15 <i>Full data breach — backup files accessible via web expose entire database contents including student records.</i> ⓘ Audit checklist: Verify database backups are stored outside web root, access-controlled, and encrypted.
ACCESS CONTROL FAILURES		2 vulnerabilities
☒ IDOR (Insecure Direct Object Reference) ACC-001 L:4 × I:4 = 16 <i>Unauthorized data access — users manipulate IDs in URLs to access other students' records or grades.</i> ⓘ Audit checklist: Verify all object references are validated server-side against the authenticated user's authorization.	☒ Privilege Escalation ACC-002 L:3 × I:5 = 15 <i>Unauthorized admin access — attacker gains elevated permissions beyond their role, potentially controlling the system.</i> ⓘ Audit checklist: Verify role-based access control is enforced server-side and privilege boundaries cannot be crossed by parameter manipulation.	

Risk Assessment Engine

NIST CSF 2.0

Risk Register								7 entries
Vulnerability	Asset	Asset Criticality	Likelihood	Impact	Risk Score	Risk Level	Category	
SQL Injection INJ-001	Student Database	4.33	4	5	20.0	Critical	Injection	
Weak Password Policy AUTH-001	Student Database	4.33	5	4	20.0	Critical	Broken Authentication	
No HTTPS / TLS DATA-001	Student Database	4.33	4	4	16.0	Critical	Sensitive Data Exposure	
IDOR (Insecure Direct Object Reference) ACC-001	Student Database	4.33	4	4	16.0	Critical	Access Control Failures	
Command Injection INJ-002	Student Database	4.33	3	5	15.0	High	Injection	
Privilege Escalation ACC-002	Student Database	4.33	3	5	15.0	High	Access Control Failures	
LDAP Injection INJ-003	Student Database	4.33	2	4	8.0	Medium	Injection	

E. Connection to Security Audit Module

A selected vulnerability will automatically generate a corresponding audit checklist item in Module 6. For example, a selected vulnerability 'Weak Password Policy' will generate a checklist item 'Verify that password policy requires a minimum of 8 characters with complexity requirements.' A selected vulnerability 'No HTTPS' will generate a checklist item 'Verify that a valid TLS certificate is installed and HTTPS is enforced sitewide.' This is a direct connection between the audit scope and the risks assessed.

F. AI Feature Integration

AI Vulnerability Explainer (Module 10) can be accessed directly from this module. An auditor can select a vulnerability of interest and request an explanation suitable for a management audience. For example, asking a question like 'Explain SQL Injection risk to university management in non-technical language' will result in a reply that includes the type of risk, business risk to the university, etc.

Threat & Vulnerability Identification NIST CSF 2

Step 1 -- Select Asset

Student Database

Vulnerability Register 7 Items [View Auto-Generated Checklist](#)

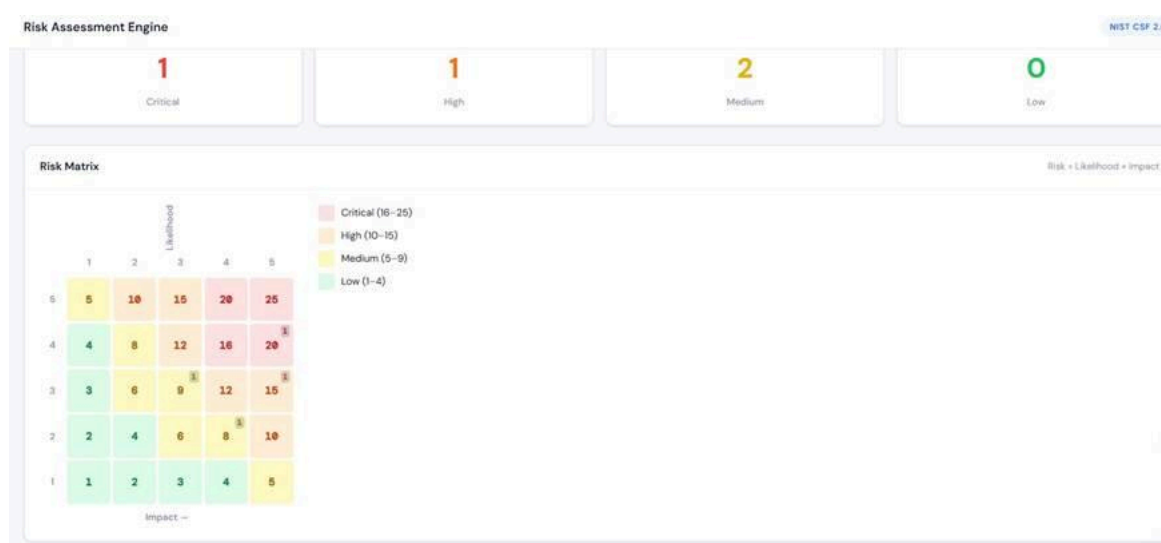
VULNERABILITY	CATEGORY	ASSET	LIKELIHOOD	IMPACT	RISK SCORE	LEVEL	ACTIONS
SQL Injection INJ-001	Injection	Student Database	4	5	20.0	Critical	Explain 🗖
Weak Password Policy AUTH-001	Broken Authentication	Student Database	5	4	20.0	Critical	Explain 🗖
No HTTPS / TLS DATA-001	Sensitive Data Exposure	Student Database	4	4	16.0	Critical	Explain 🗖
IDOR (Insecure Direct Object Reference) ACC-001	Access Control Failures	Student Database	4	4	16.0	Critical	Explain 🗖
Command Injection INJ-002	Injection	Student Database	3	5	15.0	High	Explain 🗖

5. RISK ASSESSMENT ENGINE

The risk assessment engine follows a standard risk calculation formula:

$$\text{Risk Score} = \text{Likelihood} \times \text{Impact}$$

RISK LEVEL	SCORE RANGE	ACTION REQUIRED
Low	1 – 4	Monitor and review periodically
Medium	5 – 9	Address within 90 days
High	10 – 15	Address within 30 days
Critical	16 – 25	Immediate action required

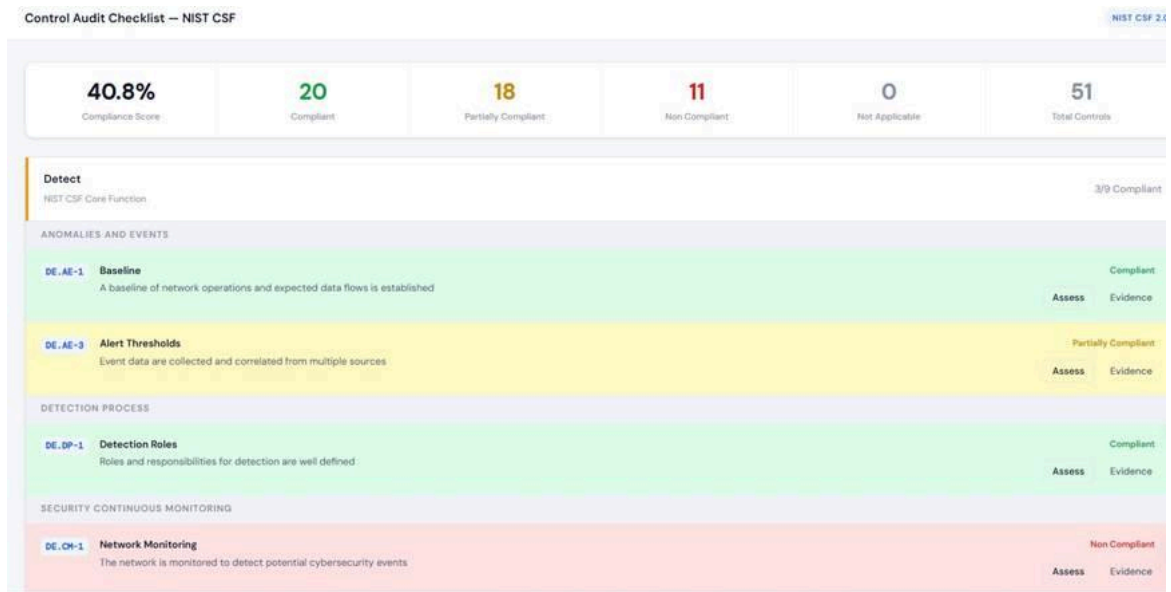


6. CONTROL AUDIT CHECKLIST (NIST CSF)

This module offers an organized audit checklist based on the five core functions of the NIST CSF. The items on the checklist can be populated either from the pre-configured framework or dynamically from the vulnerabilities identified in Module 4. The auditors then rate each control item on the checklist using one of the four levels of compliance status.

CSF FUNCTION	SAMPLE AUDIT ITEMS
IDENTIFY (ID)	Asset inventory maintained and updated; organizational risk tolerance defined; supply chain risk assessed
PROTECT (PR)	Access control policies enforced; MFA implemented; patch management process active; HTTPS/TLS enforced; data encrypted at rest and in transit
DETECT (DE)	Security audit logs enabled and reviewed; intrusion detection system active; anomaly detection configured
RESPOND (RS)	Incident response plan documented and tested; communication procedures defined; forensic evidence preservation process exists
RECOVER (RC)	Recovery plan documented and tested; backup procedures verified; lessons learned process implemented

COMPLIANCE STATUS	DEFINITION
COMPLIANT	Control is fully implemented and evidenced
PARTIALLY COMPLIANT	Control is partially implemented or documentation is incomplete
NON-COMPLIANT	Control is not implemented
NOT APPLICABLE	Control is not relevant to the system under audit



Assess Control

DE.AE-1

A baseline of network operations and expected data flows is established

Compliance Status

Compliant Partially Compliant Non Compliant

Not Applicable

Auditor Notes

Document evidence, observations, or recommendations...

Save Assessment Cancel

7. AUDIT EVIDENCE COLLECTION

For the purpose of formal audit evidence, the platform enables auditors and auditees to upload relevant evidence for each audit control item. The following types of evidence are accepted for website audits:

- Screenshots of web application security settings (e.g., HTTPS certificates, MFA login pages)

- Policy documents in PDF format (e.g., Password Policy, Incident Response Plan)
- Exports of web server, firewall, or WAF system configurations
- Scan report output from vulnerability assessment tools

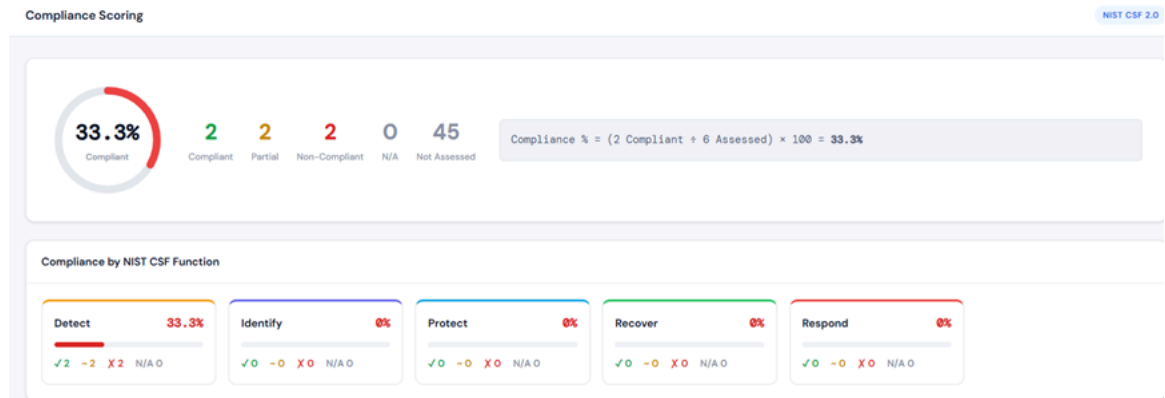
The screenshot displays the 'Evidence Management' interface. At the top right, it indicates 'NIST CSF 2.0'. The main section shows details for a specific control: 'Control ID: DE.AE-1', 'Function: Detect', 'Category: Anomalies and Events', and a 'Description: A baseline of network operations and expected data flows is established'. The 'Status' is marked as 'Compliant' in green. Below this, there is an 'Upload Evidence' section with a large dashed blue box containing an upload icon and the text 'Click to select or drag & drop a file'. Supported file types listed are PDF, PNG, JPG, DOCX, XLSX, TXT, JSON, and CONF (max 10MB). An 'Upload Evidence' button is located below the upload area. At the bottom, an 'Evidence Files' section shows a single file: 'Screenshot_2026-02-10_105551.png' with a 'View' button and a red square icon.

8. COMPLIANCE SCORING

After the control audit checklist has been completed, the platform automatically determines the overall level of compliance based on the following formula:

$$\text{Compliance (\%)} = (\text{Compliant Controls} \div \text{Total Applicable Controls}) \times 100$$

COMPLIANCE RANGE	STATUS	RECOMMENDED ACTION
≥ 85%	Compliant	Maintain controls; schedule next review
60% – 84%	Needs Improvement	Develop remediation plan within 60 days
< 60%	Non-Compliant	Immediate remediation required; escalate to management



9. AUDIT FINDING GENERATOR

The system automatically generates organized audit findings for each control item that has been rated as Non-Compliant or Partially Compliant. Each finding is presented in the standard format used in professional security audit reports:

FIELD	DESCRIPTION	EXAMPLE
Issue	Description of the non-compliant condition	No audit logging enabled on the student portal web server
Risk	Potential impact if unaddressed	Security incidents may go undetected, enabling prolonged unauthorized access
Affected Asset	The asset where the control gap exists	Student Portal (LMS) – Cloud Web Application
Recommendation	Actionable remediation guidance	Enable server-side audit logging with log retention of minimum 90 days; integrate with SIEM

Audit Findings				NIST CSF
Critical	Vulnerability: SQL Injection			CVE/OWASP: INJ-001 2026-02-2
ISSUE	AFFECTED ASSET	RECOMMENDATION		
SQL Injection detected on asset 'Student Database' with risk score 20.0.	Student Database	Remediate SQL Injection (INJ-001) by implementing appropriate security controls and patching.		
				Delete
Critical	Vulnerability: Weak Password Policy			CVE/OWASP: AUTH-001 2026-02-2
ISSUE	AFFECTED ASSET	RECOMMENDATION		
Weak Password Policy detected on asset 'Student Database' with risk score 20.0.	Student Database	Remediate Weak Password Policy (AUTH-001) by implementing appropriate security controls and patching.		
				Delete
Critical	Vulnerability: No HTTPS / TLS			CVE/OWASP: DATA-001 2026-02-2
ISSUE	AFFECTED ASSET	RECOMMENDATION		
No HTTPS / TLS detected on asset 'Student Database' with risk score 16.0.	Student Database	Remediate No HTTPS / TLS (DATA-001) by implementing appropriate security controls and patching.		
				Delete
Critical	Vulnerability: IDOR (Insecure Direct Object Reference)			CVE/OWASP: ACC-001 2026-02-2

10. AI AUDITOR ASSISTANT

10.1. Feature Description

The AI Auditor Assistant, in the above platform, includes the feature of the AI Vulnerability Explainer. The feature uses the Ollama AI, which is an open-source AI platform. The platform allows the use of local, internet-free, and API key-free large language models. The feature is used to explain the vulnerability in an easy-to-understand format, which can be used for management briefings, boardroom briefings, or organizational risk communications.

10.2. Integration: Ollama AI

The AI Vulnerability Explainer uses the locally running Ollama AI, which is an open-source AI platform. The platform allows the use of local, internet-free, and API key-free large language models. The integration is based on the following approach:

10.3. How to set up Ollama AI

Ollama AI is free and open-source. To use it within the platform, you should follow these steps:

- a. To begin with, you should download and install the Ollama AI tool. The tool can be downloaded for free from <https://ollama.com/>. The tool supports Windows, macOS, and Linux operating systems.
- b. After you have installed the tool, you should open your terminal and run the command "ollama pull llama3" to download the LLaMA 3 model.
- c. To start the Ollama AI server, you should run the command "ollama serve" to start the server running on <http://localhost:11434> by default.
- d. In the backend code, you should send a POST request to <http://localhost:11434/api/generate> with the model name and prompt.
- e. The API key is not required to use the Ollama AI tool since it runs completely offline on your local machine.
- f. Optionally, you may want to use other supported models like "mistral" or "gemma2" by running "ollama pull mistral"
- g. The Ollama AI tool should be running before running the platform since the AI features will not respond if the local server is down.

10.4. AI Interaction example:

User Question:

"Explain the risks of SQL Injection to university management in non-technical language."

AI Response (Ollama – LLaMA 3):

What it is: SQL Injection is a way for attackers to trick the university website into giving away or deleting information stored within its database by inputting specific words within a website form or search box.

Business Impact: This would allow the entire student database to be accessed by the attacker, including student grades, personal info, and financial records. This would cause the university to face many fines and legal actions.

Recommendations: The best way to stop SQL Injection is to input validation for all web forms and parameterized queries for application code. In addition, performing web application security scans will help to fix this problem.

The image shows a web application titled "AI Vulnerability Explorer" with a "phi3 mini" logo. It is powered by Ollama. The interface is divided into two main sections: "Select Vulnerability" and "Vulnerability Details".

Select Vulnerability: This section has a dropdown menu labeled "Vulnerability from Register" with the selected option "[Critical] SQL Injection — Student Database". Below the dropdown is a blue button labeled "Generate AI Explanation".

Vulnerability Details: This section displays the following information:

- Name: **SQL Injection**
- Code: **INJ-001**
- Asset: **Student Database**
- Category: **Injection**
- Risk: **Critical** Score: 20.0 (L4 × I5)

AI Analysis: This section contains the following text:

****What it is:**** SQL Injection (INJ-001) occurs when an attacker sends harmful code via a web form input field or URL parameter, aiming to manipulate the database through flawed application logic that doesn't properly sanitize user inputs. This can lead unauthorized access and data breaches as uncleaned user input may alter SQL queries executed by the back end.

****Business Impact:**** The main impact is compromised student information, including personal details or academic records being stolen or manipulated which could lead to identity fraud for students or unfair grades/promotions that misrepresent their performance and efforts. This undermines the integrity of educational data management systems at universities.

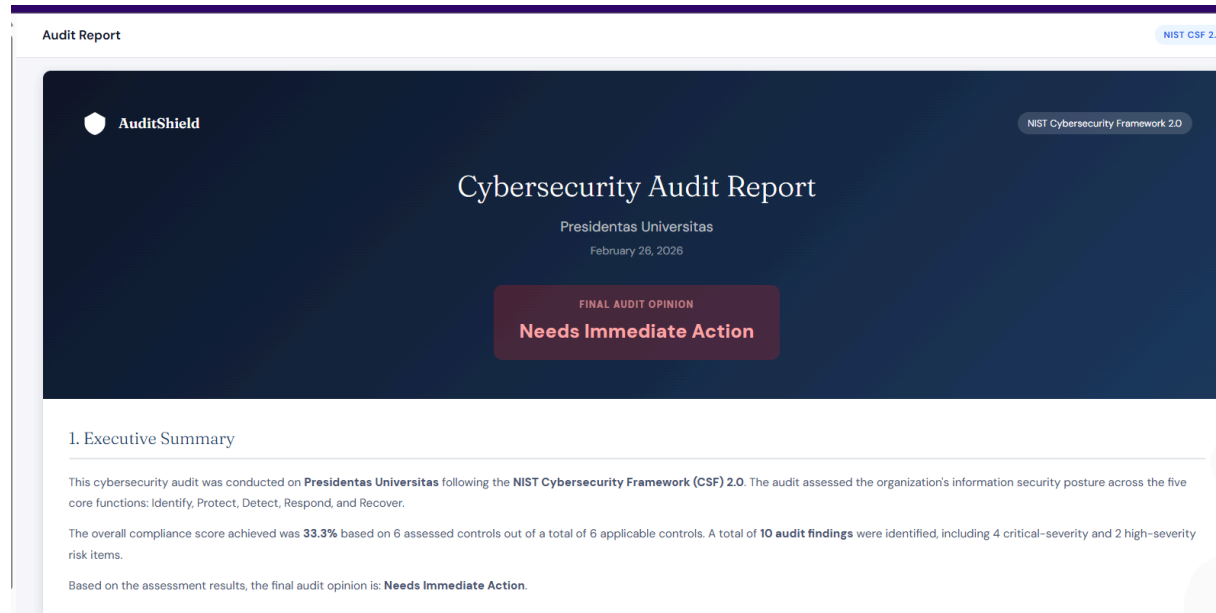
****Example in a university:**** An attacker inputs malicious SQL code into an online form meant for submitting assignment feedback, where it manipulates a search query to reveal all student grades or personal information stored in the database instead of just processing their feedback.

****Recommended Control:**** The primary control is implementing prepared statements with parameterized queries that treat user input strictly as data and not executable code. Educating developers about secure coding practices, regularly updating software to patch vulnerabilities (including using security headers), and conducting frequent security assessments can further mitigate this risk effectively in a university setting where sensitive student information is frequently handled online.

11. REPORT GENERATOR

11.1 Security Audit Report

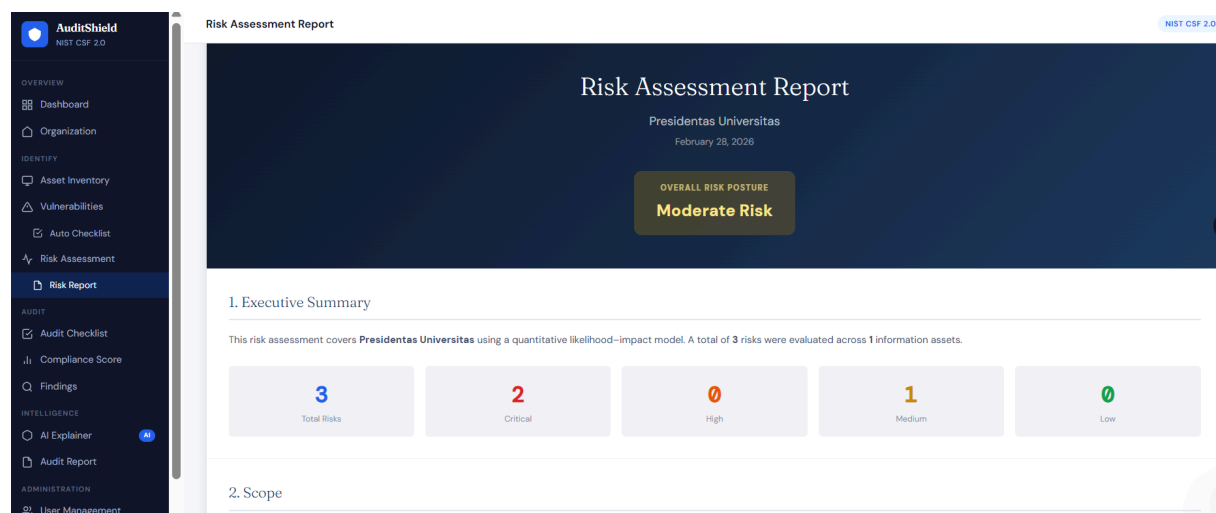
The platform compiles all audit information including asset inventory, vulnerability assessment, compliance scores, findings, evidence, and AI recommendations; into a well-structured Security Audit Report. The report is exportable as a PDF generated server-side using ReportLab and features a professional cover page, executive summary, methodology section, and findings register.



 Audit_Report_Presidentas_Universitas_20260227 (1).pdf

11.2 Risk Assessment Report

The Risk Assessment Report Generator produces a standalone risk-focused report separate from the Audit Report. It is aligned with NIST CSF reporting standards and covers: risk register, critical and high risk details, asset exposure summary, risk treatment plan, and overall risk posture conclusion. It is exportable as PDF, viewable in-app, and printable via browser.



12. USER MANUAL

This chapter provides step-by-step instructions for using the AI-Assisted Cybersecurity Risk Assessment and Security Audit Platform. Follow each section in order when conducting an audit for the first time.

12.0 Before You Begin – Downloading the Platform

The platform must be downloaded before setup. Visit the project repository at: <https://github.com/hal-imaxabdi/AI-ASSISTED-CYBERSECURITY-RISK-ASSESSMENT-SECURITY-AUDIT-PLATFORM-.git>

You can either clone the repository using Git or download it as a ZIP file. Once downloaded, navigate into the project folder in your terminal before proceeding with the steps below.

12.1 Getting Started – System Setup

Before launching the platform, complete the following setup steps:

Step 1. Download and install Ollama AI from <https://ollama.com> (supports Windows, macOS, Linux).

Step 2. Open your terminal and run: `ollama pull llama3`

Step 3. Start the Ollama server by running: `ollama serve`

Step 4. Launch the platform application. Make sure Ollama is running before opening the platform or the AI features will not work.

12.2 Logging In

Step 1. Open the platform in your browser.

Step 2. Enter your username and password on the login page.

Step 3. Select your role: Admin, Auditor, or Auditee. Each role will see a different dashboard. Admin manages users and assigns audits. Auditor conducts risk

assessments and fills in audit checklists. Auditee views results and uploads evidence upon request.

12.3 Setting Up the Organization Profile (Admin or Auditor)

Step 1. From the dashboard, navigate to Organization Profile.

Step 2. Fill in the organization name, business sector, number of employees, and system type (e.g., Website).

Step 3. Click Save. The system will automatically determine the organization's exposure level based on the information entered.

12.4 Registering Assets

Step 1. Go to Asset Inventory from the main menu.

Step 2. Click Add New Asset.

Step 3. Enter the asset name (e.g., Student Portal), owner (e.g., IT Department), location (e.g., Cloud Server – AWS), type (e.g., Web Application), and CIA values for Confidentiality, Integrity, and Availability on a scale of 1 to 5.

Step 4. Click Save. Repeat for all assets related to the audit. The system will calculate each asset's criticality score automatically.

12.5 Identifying Vulnerabilities

Step 1. Navigate to Threat and Vulnerability Identification from the menu.

Step 2. Select the asset you wish to assess from the dropdown list.

Step 3. A checklist of 19 OWASP-based vulnerabilities will appear. Tick all vulnerabilities that are detected or suspected on the selected asset.

Step 4. Click Confirm Selection. The system will automatically assign a likelihood score, business impact description, and risk score for each selected vulnerability. It will also generate corresponding checklist items in the Control Audit module.

Optional: To get an AI explanation of any vulnerability for management, click the AI Explain button next to the vulnerability name and type your question (e.g., “Explain SQL Injection risk to university management in non-technical language”).

12.6 Completing the Control Audit Checklist

Step 1. Navigate to Control Audit Checklist from the menu.

Step 2. The checklist will be pre-populated based on the vulnerabilities you selected and the five NIST CSF functions: Identify, Protect, Detect, Respond, and Recover.

Step 3. For each control item, select one of the four compliance statuses: Compliant, Partially Compliant, Non-Compliant, or Not Applicable.

Step 4. Click Save after completing each section. When all items are filled in, the system will automatically calculate the overall compliance percentage.

12.7 Uploading Audit Evidence

Step 1. Inside the audit checklist, locate the control item you want to attach evidence to.

Step 2. Click Upload Evidence next to that control item.

Step 3. Select your file. Accepted file types are screenshots (PNG, JPG), policy documents (PDF), configuration exports, and scan report outputs.

Step 4. Click Confirm Upload. The file will be stored and linked to that specific control item as formal audit evidence.

12.8 Generating Reports

Step 1. Navigate to Report Generator from the main menu.

Step 2. Choose which report to generate: Security Audit Report or Risk Assessment Report.

Step 3. Click Generate Report. The system will compile all audit data including the asset inventory, vulnerability findings, compliance scores, audit evidence, and AI recommendations into a structured PDF report.

Step 4. Click Download to save the report as a PDF file, or use the Print button to print directly from the browser.

12.9 Using the AI Auditor Assistant

Step 1. Make sure Ollama is running on your machine (see Section 12.1).

Step 2. Navigate to AI Vulnerability Explainer from the main menu.

Step 3. The page will display a dropdown list labelled Select Vulnerability. This list is automatically populated with vulnerabilities that have already been registered under your assets, showing their risk level, name, and associated asset (e.g., *[Critical] SQL Injection — Library Management System*).

Step 4. Select a vulnerability from the dropdown.

Step 5. Click Generate AI Explanation. The system will display the vulnerability details panel on the left, showing the vulnerability name, code, asset, category, risk level, and risk score. On the right, the AI Analysis panel will generate a plain-language explanation covering what the vulnerability is, its business impact with a real-world example, and recommended controls.